

MDDC: Qualification-Gated Defense-Capital Accounting for Context-Qualified AI Security

Yi Lv, Cheng Wang, *Senior Member, IEEE*, and Changjun Jiang, *Fellow, IET*

Abstract—Modern security teams receive vulnerability reports, upstream patches, code context, validation feedback, and AI-generated candidates faster than they can decide which artifacts are safe to reuse. Multi-Dimensional Dual-Cycle (MDDC) is used here as the state model for this admission problem. Its technical core is qualification-gated defense-capital accounting (QG-DCA), an admission method that separates admitted defense capital from validation debt. MDDC preserves its four-dimensional defense space—space, time, knowledge, and architecture—and operationalizes it through five measurable state variables: threat pressure, remediation debt, validation debt, qualified knowledge capital, and resource allocation. The AEC/CEC dual-cycle view motivates the shared state, but this paper evaluates the artifact-admission method rather than claiming closed-loop deployment.

We evaluate MDDC with public vulnerability intelligence and repair artifacts from NVD, CISA KEV, EPSS, VulGenie/ASRDataset, CVEfixes, BigVul, MegaVul, security-kg, CIRCL vulnerability-scores, and replayable repair pools. The central empirical result is not that stronger models automatically repair vulnerabilities. It is that ungated context creates false security capital. Repository applicability overstates qualified repair delivery by $4.43\times$, and an abstention gate prevents 22/80 false-confident deliveries. On ASRDataset, the strict hard-capital gate admits 99/131 reference-agreeing rules and admits 0 controls in a 5,000-trial same-category different-rule stress test. On CVEfixes, the strict gate admits 6240/12668 reference-agreeing patch-context pairs and reduces same-category false admissions by 83.2% relative to structural-only admission. On BigVul, the same accounting pattern admits 2247/4432 reference-agreeing pairs and reduces same-category structural false admissions by 85.8%. At matched recall, tuned coverage-only baselines dominate the fixed strict gate. QG-DCA therefore reports the full operating curve and selects the operating point under an explicit validation-debt cost. Under the declared cost model, the selected points are coverage-only thresholds with recall 0.513 and false-admission rate 0.061 on CVEfixes, and recall 0.579 and false-admission rate 0.032 on BigVul. A sensitivity sweep over 875 cost models per dataset again selects coverage-only in 875/875 cases on both datasets. External component and stress ablations show that provenance gating reduces coverage-only false admissions from 0.00067 to 0 on 5954 MegaVul true pairs and 5954 same-CWE controls, rejects 10% spoofed provenance without false admission, and records 50% missing positive provenance as validation debt rather than capital. In a single-seed 40-task GLM-assisted oracle-calibration sample, GLM recalls 19/20 objective positives (Wilson 95% CI 0.764–0.991) but its candidate gate also marks 10/20 objective negatives (CI 0.299–0.701); QG-DCA keeps the 19/20 positive admits and admits 0/20 negatives (CI 0–0.161) through the objective patch-differential gate. Thus, QG-DCA is evaluated as an operating-point, provenance-verification,

and debt-accounting method around generators rather than an unconditional classifier or LLM judge.

The boundary is also explicit. A patch-differential oracle cross-check validates 55/99 strict ASR admissions, with Wilson 95% CI 0.457–0.650, and has a 15.1% cross-category false-validation rate, so it is reported as boundary evidence rather than behavioral proof. The frozen 30-task all-gate repair run yields 1/30 primary security-qualified delivery and 0/30 original deployment-qualified deliveries; one same-candidate recovered-native all-gate case is reported separately as post-hoc existence evidence. The KEV activation analysis yields calibrated frontiers of 0.275 and 0.325, reproduced from saved replay curves, showing when CEC activation should fall back to AEC-only. MDDC therefore claims a reproducible measurement and admission-control method for AI defense capital, not automatic AI repair or deployment-level superiority.

Index Terms—AI security, vulnerability repair, qualification gates, validation debt, defense capital, empirical software security.

I. INTRODUCTION

Security operations increasingly face a qualification problem. Public exploit intelligence, upstream patches, repository context, validation feedback, and model-generated candidates arrive faster than organizations can validate them. The binding constraint is therefore not only generation capacity. It is admission capacity: deciding which artifacts are safe enough to become reusable defense knowledge.

This distinction matters because AI-assisted security tools can raise both capability and debt. A model can generate a plausible patch, a rule, or an oracle quickly, but each candidate still needs evidence. If a system counts repository-applicable patches, retrieved examples, or confident model outputs as security capital before they pass a security gate, it hides validation debt as progress. Our experiments show that this failure mode is not hypothetical: repository applicability overstates qualified security delivery by $4.43\times$ in the repair pool, and a two-state deliver/reject policy would count 22/80 missing-evidence cases as deliveries.

This paper studies admission as a first-class security measurement problem. We propose Multi-Dimensional Dual-Cycle (MDDC) as a measurement method for *context-qualified defense capital*. MDDC preserves the original four-dimensional dual-cycle idea. Space captures attack surfaces and resource distribution. Time captures vulnerability arrival, repair delay, and recovery. Knowledge captures reusable properties, rules, and oracles. Architecture captures the AEC/CEC coupling, routing policy, validation gate, and feedback topology. These dimensions are operationalized by five measurable variables: threat pressure, remediation debt, validation debt, qualified knowledge capital, and resource allocation.

Yi Lv is with the Department of Computer Science and Technology, Tongji University, Shanghai 201804, China (e-mail: lvyi@tongji.edu.cn).

Cheng Wang and Changjun Jiang are with the Department of Computer Science and Technology, Tongji University, Shanghai 201804, China, and also with the Key Laboratory of Embedded System and Service Computing, Ministry of Education, Tongji University, Shanghai 201804, China (e-mail: cwang@tongji.edu.cn; cjjiang@tongji.edu.cn).

The technical core inside MDDC is *qualification-gated defense-capital accounting* (QG-DCA). QG-DCA is not a particular LLM, patch generator, scanner, or triage score. It is an admission and accounting layer around such tools. Given a candidate artifact, its context, and its evidence, QG-DCA decides whether the artifact updates qualified defense capital, is rejected, or remains validation debt.

The core invariant is simple. An AI-produced patch, rule, oracle, or routing decision is counted as knowledge capital only after explicit qualification gates pass. Otherwise it remains rejected output or validation debt. This framing separates MDDC from generic LLM patch repair. The paper does not ask whether a stronger model can produce plausible patches. It asks when context can be transformed into qualified security objects, when it must be rejected or abstained, and how much operational debt is created by counting the wrong objects.

The paper makes three contributions:

- 1) **Measurement problem:** We formulate AI defense admission as a defense-capital accounting problem over the MDDC state space, where generated artifacts and admitted capital are different objects.
- 2) **Method:** We introduce QG-DCA, a three-action admission method that maps candidate artifacts to ADMIT, REJECT, or ABSTAIN, updates $H_q(t)$ only after gates pass, and recalibrates CEC activation frontiers for new deployments.
- 3) **Evidence:** We show across ASRDataset, CVEfixes, BigVul, and repair audit pools that QG-DCA exposes false security-capital admission, compares operating points against structural, score, confidence, and risk-only baselines, and selects lower-debt policies when a fixed gate is dominated.

The empirical conclusion is deliberately conditional. MDDC does not establish deployment-level repair superiority. Instead, it provides a reproducible gate chain that shows where context helps, where it fails, and when admission should stop.

II. RELATED WORK

Moving Target Defense and endogenous security study how architectural diversity and dynamic execution can reduce attacker advantage [5], [7]. These approaches usually emphasize runtime uncertainty and heterogeneity. MDDC keeps the architectural viewpoint, but it shifts the empirical question from runtime diversity to knowledge admission: which artifacts can safely update the defense state?

DevSecOps and security automation improve scanning, testing, and deployment workflows [44], [47]. These pipelines already contain many gates, such as build checks, static analyzers, and regression tests. MDDC adds a measurement layer over such gates. It treats missing evidence as an explicit outcome and separates repository applicability from security qualification.

Recent AI repair, property generation, and agentic verification systems show that large models can generate patches, rules, and formal properties under favorable conditions [63], [64]. These systems motivate the knowledge-generation side of MDDC, but they do not remove the need for admission

TABLE I
MDDC CONCEPTUAL DIMENSIONS AND OPERATIONAL VARIABLES

Dimension	Operational variables	Evidence source
Space	Threat distribution; resource allocation	NVD, KEV, EPSS, audit pool
Time	Remediation debt; validation debt; recovery delay	KEV replay, gate logs
Knowledge	Qualified properties, rules, oracles; yield ϵ	CVEfixes, VulGenie, ASRDataset
Architecture	Control topology; routing; gate order	Replay and gate-ordering experiments

control. A generated object is not defense capital because it is fluent or because it resembles an upstream patch. It must pass evidence gates that are appropriate to the object type.

The closest conceptual neighbors are security-measurement and empirical software-security studies that distinguish observable proxies from true outcomes. Defect-prediction and bug-report studies show that code metrics and issue reports can support prioritization, but also that transfer, label quality, and misclassification can distort conclusions [51]–[54]. Vulnerability-prediction studies reach a similar boundary: complexity, churn, developer activity, or text features may identify risky components, but false positives and actionability remain central concerns [55], [56]. MDDC follows this measurement tradition but changes the measured object. It does not predict vulnerable files. It measures whether generated patches, rules, or oracles have enough evidence to update $H_q(t)$. The contribution is therefore not a new model prompt, patch generator, or scanner. It is a qualification-gated accounting system for deciding when AI-generated security artifacts may become defense capital.

III. MDDC STATE MODEL AND QG-DCA METHOD

A. State Model: Dimensions and Variables

MDDC originates from a two-loop view. The observation side records threat pressure, unresolved vulnerability debt, and failed validations. The generation side proposes patches, rules, oracles, and routing decisions from code context, patch context, protocol/API context, validation feedback, and historical rule memory. This paper evaluates the admission method that sits between those sides. It does not claim that a live closed-loop AEC/CEC system has been deployed.

MDDC uses four conceptual dimensions and five operational variables. Table I gives the mapping.

At month t , the shared state is

$$s_t = (P_t, D_t^R, D_t^V, H_t, U_t), \quad (1)$$

where P_t is threat pressure, D_t^R is remediation debt, D_t^V is validation debt, H_t is qualified knowledge capital, and U_t is resource allocation.

The observation side publishes threat pressure, failed validations, and high-risk unresolved tasks. The generation side publishes candidate properties, rules, oracles, and repair candidates. The qualification invariant is:

$$\Delta H_t > 0 \Rightarrow G(a_t, c_t, e_t) = 1, \quad (2)$$

where G is an explicit gate over the artifact a_t , its context c_t , and evidence e_t . If $G = 0$, the artifact is rejected or left as validation debt. If evidence is insufficient, the controller abstains.

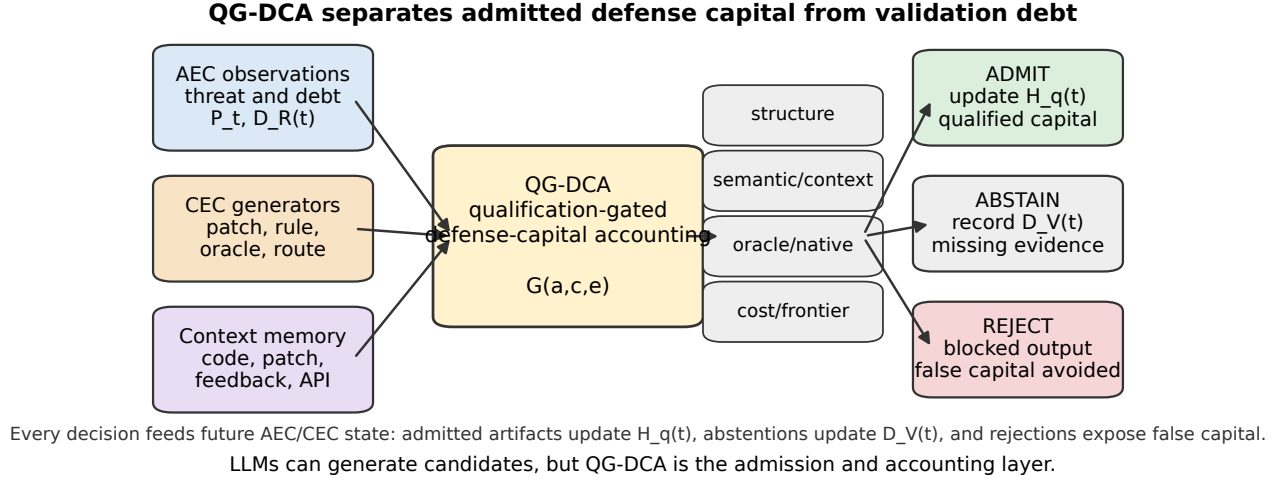


Fig. 1. QG-DCA inside the MDDC framework. Candidate patches, rules, oracles, and routing decisions are generated from AEC observations, CEC generators, and context memory. The QG-DCA admission layer separates admitted defense capital from rejected output and validation debt. This is an accounting and control method, not a standalone LLM.

TABLE II
FORMAL QG-DCA ADMISSION OPERATOR

Element	Definition
Input	State $s_t = (P_t, D_t^R, D_t^V, H_t, U_t)$, candidate artifact a_t , context c_t , and evidence bundle e_t
Gate predicate	$G_k(a_t, c_t, e_t) = 1$ only if the artifact-specific evidence gate k passes
Action	$\pi(s_t, a_t) \in \{\text{ADMIT}, \text{REJECT}, \text{ABSTAIN}\}$
Capital update	$H_q(t+1) = H_q(t) + w(a_t)$ only under ADMIT; otherwise $\Delta H_q = 0$
Debt update	Rejected artifacts are recorded as unsafe/irrelevant output; missing evidence increments validation debt D_t^V
Operating point	Gate thresholds are selected by validation-window replay and must report recall, false admission, precision, and validation-debt cost

Fig. 1 shows the role of QG-DCA inside MDDC. AEC observations and CEC generators provide candidate artifacts and context. QG-DCA then applies artifact-specific evidence gates and emits one of three accounting decisions. LLMs, static analyzers, or human procedures can generate candidates, but none of them directly update $H_q(t)$. The update happens only after the admission layer validates the evidence.

B. Method: QG-DCA Admission Operator

MDDC exposes three admission actions:

$$\pi(s_t, a_t) \in \{\text{ADMIT}, \text{REJECT}, \text{ABSTAIN}\}. \quad (3)$$

ADMIT updates H_t . REJECT blocks unsafe or irrelevant artifacts. ABSTAIN records missing evidence without pretending that a delivery succeeded. This third action is essential in security measurement, because missing validation evidence is not success.

Different artifact types require different evidence. Table III summarizes the gates used in this paper. The table is also the main accounting rule: each artifact is counted only at the strongest gate that it passes.

For CEC activation, MDDC also uses a yield frontier:

$$\hat{g}_{CEC} = q_{\text{capital}} \cdot s_{\text{quality}}. \quad (4)$$

Here q_{capital} is the qualified-capital coefficient and s_{quality} is the downstream quality of that capital. A CEC path is activated only when $\hat{g}_{CEC}$ crosses a calibrated frontier; otherwise the controller falls back to AEC-only, rejects, or abstains. The frontier is estimated from a fixed validation window by sweeping effective CEC gain under the same task arrivals, budget, seeds, and policy definitions. A deployment using different pressure, resources, or gates must recalibrate the frontier rather than reuse the paper's numeric thresholds. This rule prevents the dual-cycle architecture from becoming an always-on generator of validation debt.

The recalibration procedure is part of the method. For a new deployment, the operator first freezes a validation window, the task-arrival stream, the available resource budget, the gate chain, and the random seeds used for replay. It then estimates q_{capital} from the observed qualified-capital yield in that window and sweeps a grid of candidate effective CEC gains while replaying the same arrivals and budgets. The activation frontier is the smallest grid value that produces a positive held-out security-efficiency margin, or a conservative validation-period margin if the deployment requires stricter control. Rolling-origin and budget-sensitivity checks then report how much the frontier moves. Only after this recalibration can $q_{\text{capital}} s_{\text{quality}}$ be compared with the local frontier. Thus, the reported 0.275 and 0.325 values are reproducible calibration outputs for our data and policy, not universal constants.

For admission gates, QG-DCA also evaluates an operating curve. For a policy threshold θ , let R_θ be true-pair recall, F_θ the same-category false-admission rate, L_θ the review load, and α a false-admission budget. The selected operating point is

$$\theta^* = \arg \max_{\theta: F_\theta \leq \alpha} (R_\theta - c_F F_\theta - c_M (1 - R_\theta) - c_L L_\theta). \quad (5)$$

This rule is intentionally policy-neutral. If a simpler coverage-only threshold has lower validation debt under the declared cost model, QG-DCA selects that threshold rather than de-

TABLE III
QUALIFICATION GATES USED TO ADMIT CONTEXT-DERIVED DEFENSE CAPITAL

Artifact	Candidate source	Admission evidence	Failure state
Patch	LLM repair, RAG repair, property-guided repair	Applies to repository; passes task-specific static oracle; for deployment claims, also passes native and dynamic gates	Patch application debt, static security debt, native/dynamic debt
Rule or property	Upstream patch, ASR rule memory, generated property	Structural fields present; parent/upstream discrimination where available; semantic or oracle-based admission	Candidate rule, patch pattern, under-specified rule
Oracle	Patch diff, code slice, existing tests, protocol/API context	Executable predicate; parent fails and upstream passes; vacuity filtering	Missing evidence, vacuous oracle, exact-diff overfit
Routing decision	Frozen metadata policy	Pre-specified policy evaluated on held-out tasks; cost and abstention recorded	Validation debt, abstention, failed frontier crossing

TABLE IV
PUBLIC DATA AND ARTIFACT PROVENANCE USED BY THE MEASUREMENT CHAIN

Source	Provenance	Fields used	Role in this paper
VulGenie/ASRDataset	Zenodo record 18427597; ASRDataset.zip and VulGenie.zip; local manifest records checksums	Ground-truth XML rules, output rules, vulnerability categories, API/rule identifiers, comments	ASR rule-capital admission and negative controls
CVEfixes	CVEfixes v1.0.8, Zenodo, DOI in [60]	CVE/CWE metadata, vulnerability-fixing commits, commit messages, patch text, project identifiers	Patch-context replication, operating-curve comparison, repair-task source
BigVul	MSR'20 BigVul dataset [61]; CSV file <code>all_cpp_release2.0.csv</code> ; SHA256 begins <code>02970f6d07f2</code> , full hash in metadata	CVE/CWE metadata, pre/post functions, commit identifiers, patch-line text	LXXIX third-dataset replication of gate-accounting and false-admission reduction
NVD, CISA KEV, EPSS	Official public feeds [57]–[59]	CVE publication metadata, CVSS/EPSS scores, KEV dates, remediation-window metadata	Threat-pressure replay, remediation-debt proxy, activation-frontier calibration
Repair audit pools	CVEfixes-derived replay tasks and saved gate logs	Apply, static, native, dynamic, security-oracle, and abstention outcomes	Metric inflation, deployment boundary, recovered-native existence, and utility-gate baselines

fending a fixed strict gate.

The cost model is also auditable. In the sensitivity check, c_F , c_M , c_L , and α are swept over 875 combinations per dataset. The selected policy is reported for each combination. This prevents numeric cost constants from becoming hidden assumptions: if the selected policy changes under a plausible cost region, that instability is part of the accounting result rather than an exception.

IV. DATA AND PROTOCOL

The empirical evidence uses public and reproducible sources: CVEfixes for vulnerability-fixing commits [60], NVD CVE metadata [57], CISA KEV [58], EPSS [59], VulGenie/ASRDataset artifacts, and BigVul [61]. The default public replay window is 2018–2025. The repair audit pool contains 80 replayable tasks with repository, static, native, or dynamic gates depending on evidence availability. We do not use NVD `lastModified` as a patch time and do not treat CISA due dates as actual remediation dates.

A candidate can be counted only at the strongest gate it passes. Repository application alone is not qualified delivery. A static oracle checks a task-specific security predicate. A native gate checks project tests or build-level regressions. A dynamic oracle checks behavior. A rule or property can update $H_q(t)$ only after structural and semantic or oracle-based admission.

The protocol has three safeguards. First, every positive claim is paired with a boundary condition. Static-oracle success is not deployment success. Structural rule admission is not semantic correctness. Second, missing evidence is recorded as ABSTAIN, not as failure or success. Third, routing evidence is restricted to the pre-specified 5/14 held-out replay.

For ASR rule capital, the deterministic gate uses public artifact fields and XML rule content. The reference side is the ASRDataset GroundTruth XML, and the candidate side is the corresponding ASRDataset output rule; the gate therefore measures agreement against a public benchmark reference rather than author-created expected answers. A candidate must have an output rule, matching vulnerability category, exact rule or method identity, and a checkable conditional or protection plus security/vulnerability text. Context support requires condition overlap through argument, parameter, conditional type, or protection call, plus security-comment, vulnerability-comment, or security-token overlap. The strict gate additionally rejects unresolved signatures and is used as one hard $H_q(t)$ admission operating point. Balanced and lenient gates are reported only as candidate-pool and sensitivity evidence. Paid or model-produced semantic labels are excluded from the gate and used only for post-hoc agreement checks.

For independent replication, the same accounting pattern is applied to CVEfixes rather than ASRDataset. The reference side is public CVE/CWE text, and the candidate side is the corresponding commit message, security keywords, and patch diff. Because CVEfixes does not provide ASR rule XML, this is a patch-context benchmark-agreement replication, not a human semantic label or deployment gate. The third-dataset replication repeats the same admission-accounting logic on BigVul, using vulnerable/fixed function context and CVE/CWE metadata. A patch-differential oracle cross-check is reported separately as boundary evidence because a patch-diff surrogate can validate whether a rule aligns with upstream changes, but it cannot prove full behavioral correctness. In the GLM-assisted oracle-calibration experiment, GLM is used only to propose candidate predicates from patch and context fields. The qualification label is still assigned by the objective

TABLE V
OPERATIONAL MEASUREMENT TRACE FROM CONTEXT ARRIVAL TO QUALIFIED CAPITAL

Gate stage	P_t pressure	D_t^R remediation debt	D_t^V validation debt	H_t qualified capital	U_t allocation
Threat replay	KEV/EPSS/CVSS arrival pressure	Risk-weighted open vulnerabilities	Not yet evaluated	No update	Static, AEC-only, MTD-like, or MDDC budget
Candidate generation	Tasks selected from pressure/debt pool	Candidate patch backlog	Generated candidates requiring gates	No update before evidence	Model calls, retrieval, property context
Qualification gates	High-risk tasks prioritized	Failed patches remain debt	Apply, static, native, dynamic, semantic, and evidence gaps	Only gate-passing artifacts update $H_q(t)$	Ordered gate policy and abstention
Rule/oracle admission	Patch/API context converted to rule pressure	Uncovered tasks remain remediation debt	Vacuous, patch-pattern, or under-specified rules remain validation debt	Structural ASR candidates; objective semantic/oracle-admitted subset	Objective semantic gate, oracle construction, expert-calibration target
Deployment boundary	Same task pressure under all gates	Unfixed tasks remain open	Native/dynamic failures recorded	Deployment capital only when full chain passes; one recovered-native existence case is separated from rate claims	Fallback or abstain instead of activation

patch-differential gate; model output is never used as ground truth.

The main research questions are:

- **RQ1:** Can context become qualified rule, property, or oracle capital?
- **RQ2:** Why are qualification gates necessary?
- **RQ3:** Do raw patches, RAG, or stronger models cross the knowledge-gain frontier?
- **RQ4:** What boundary appears under real vulnerability pressure when qualification yield is low?
- **RQ5:** Does the gate policy deliver deployable repairs?

Table V shows how the five state variables are instantiated in the empirical gate chain. This table is the short-paper substitute for the longer control-model derivation in the full version.

V. EMPIRICAL RESULTS

A. RQ1: Can Context Become Qualified Capital?

Partially, and only after contraction through gates. Property capital has the desired accumulation shape, with 86.9% held-out coverage and a concave accumulation curve in the property-capital audit. Yet early property-guided delivery remains low. Patch-to-rule experiments show the contraction explicitly: 38 patch contexts become 16 parent/upstream-qualified predicates, and the current machine-assisted semantic gate reduces them further to one reusable-invariant candidate, with six additional abstraction candidates. This is the accounting result the method is designed to expose, not a claim that independent semantic capital has already been fully established.

The ASRDataset/VulGenie line gives the strongest rule-capital evidence. Across all 131 ASR tasks, 112 pass the structural candidate-rule gate and 108 pass the stricter exact-RuleID gate. A deterministic non-LLM semantic-proxy gate admits 57/131 tasks under strict RuleID agreement and exact security-comment token overlap, with Wilson 95% CI 0.353–0.521. A context-enriched blind packet first admitted 11/15 rules under strict API/category/checkability/context predicates, with shuffled negative controls admitting 0. The full objective gate then admits 99/131 rules, with Wilson 95% CI 0.676–0.821. Balanced and lenient gates admit 107/131 and 110/131 as

candidate-pool sensitivities. In 5,000 same-category different-rule control trials, the strict gate admits 0 controls, whereas the balanced gate admits a mean of 22.685 and a maximum of 35 close non-matches. The strict gate is therefore a conservative $H_q(t)$ operating point, while balanced and lenient gates remain screening evidence. Post-hoc agreement with the earlier 36-row paid semantic audit is 29/36, but those labels are not used by the gate.

The CVEfixes replication tests whether the gate-accounting pattern is an ASRDataset artifact. On 12,668 public vulnerability-fixing pairs, a structural-only baseline admits 10,302 reference-agreeing pairs but also admits 82.2% of same-category different-CVE controls. The strict MDDC gate admits 6,240 reference-agreeing pairs, with Wilson 95% CI 0.484–0.501, and admits 13.8% of same-category controls. This reduces false admissions by 83.2% relative to the structural baseline. The result is deliberately limited to patch-context benchmark agreement, but it supports the method claim that explicit qualification reduces false capital outside ASRDataset.

The third-dataset replication uses BigVul. On 4,432 BigVul vulnerable/fixed pairs, structural-only admission accepts 93.0% of reference-agreeing pairs but also accepts almost all same-category different-CVE controls. The strict MDDC gate accepts 2,247 reference-agreeing pairs, with Wilson 95% CI 0.492–0.522, and reduces same-category false admissions by 85.8% relative to structural-only. This matters because BigVul uses C/C++ function-level vulnerability context rather than ASR rule XML or CVEfixes commit records. It supports the portability of the accounting principle, while still remaining patch-context evidence rather than deployment evidence.

The high BigVul structural-control rate is not used as a strawman success condition. It exposes the weakness of a common proxy: treating the existence of a parsable vulnerability/fix pair, a CVE/CWE label, and changed code as reusable capital. BigVul same-category controls are deliberately hard negatives, because they share broad vulnerability classes and C/C++ patch structure with true pairs. Structural-only therefore admits nearly all controls. The strict gate adds category consistency and token-level patch-context support, which lowers false admission but also sacrifices recall. The

comparison shows the tradeoff between artifact availability and qualified admission; it does not claim that structural-only is a deployable baseline.

The patch-differential oracle check tests the stronger claim that strict ASR admissions behave like executable change predicates. The result is mixed: 55/99 strict admissions validate, with Wilson 95% CI 0.457–0.650, but cross-category controls still validate at 15.1% on average. This is why the oracle check is treated as a boundary result. It shows that objective admission is valuable for screening and accounting, but the current patch-differential surrogate is not strong enough to license a deployment mini-trial.

The context-to-oracle pilot reaches the same conclusion from another direction. CVE-only context yields 0/15 qualified oracles. Adding patch context gives many parent/upstream-discriminating predicates, but code-slice review and vacuity filtering are needed. The strongest pilot arm, CVE plus patch plus code slice, gives 11/15 qualified exact-diff oracle candidates. These are useful measurement artifacts, not full security proofs.

Fig. 2 condenses the main empirical chain. The first row shows why naive repair metrics and structural admission overstate qualified capital. The second row shows the cross-dataset and control-policy boundary: BigVul confirms the false-admission reduction pattern, utility gates avoid confidence-driven debt, and the activation frontier explains why low-yield CEC should fall back to AEC-only.

B. RQ2: Why Are Qualification Gates Necessary?

Experiments on gate ordering and metric accounting show that naive metrics are unsafe. In 222 generated candidates, 31 apply to the repository but only 7 pass available static security gates. Counting repository applicability as capital would inflate qualified delivery by $4.43\times$ and admit 24 unqualified applicable candidates. In the 80-task upstream audit pool, git replay succeeds for 76 tasks, but only 54 have expanded security evidence. A three-state abstention gate therefore records 54 evidence-backed deliveries, 22 missing-evidence abstentions, and 4 replay rejects.

Gate order also matters. Exhaustive checking wastes validation resources, while apply-only or native-first gates can admit states with no security evidence. MDDC ordered checking prevents unsafe admissions in the held-out gate replay and saves 20 weighted cost units relative to exhaustive checking. The point is not that the current gate order is universal. It is that gate order is measurable and must be part of the defense policy.

The external baseline comparison provides direct comparison targets. On CVEfixes controls, CVSS-only admission has a 47.9% same-category false-admission rate, and structural-only admission has an 82.2% false-admission rate. The strict gate reduces this rate to 13.8%, a 71.2% reduction relative to CVSS-only and an 83.2% reduction relative to structural-only. On the utility pool, a Qwen confidence-only policy admits all 80 candidates and produces 57.5 false admissions per 100 admissions; a DeepSeek score-only policy admits fewer candidates but still produces 71.4 false admissions per

100 admissions. The utility gate admits 33 candidates, all true positives under the measured utility label. This does not prove that MDDC is a better patch generator. It proves the narrower claim that qualification gates can reduce false capital admission and validation debt relative to score, confidence, and structural baselines.

The matched-recall and operating-curve analyses then test whether this advantage is only a recall artifact. At the strict gate's true-pair recall, strict admission is much better than risk-score and random admission, but a tuned coverage-only baseline has a lower same-category false-admission rate on both CVEfixes and BigVul. The full operating curve resolves this boundary by changing the claim. QG-DCA is not a fixed strict gate. It is a protocol for exposing candidate operating points, recording the validation-debt cost model, and selecting a point under that model. Fig. 3 shows that the declared debt-adjusted objective selects coverage-only thresholds on both CVEfixes and BigVul. Table XI reports the selected points and the fixed strict reference point. This result prevents a stronger classifier claim, but it strengthens the measurement-method claim because the method can reject its own earlier operating point when a simpler policy dominates.

A cost-model sensitivity sweep confirms that this conclusion is not caused by one hand-picked set of constants. We vary false-admission cost over $\{0.5, 1, 2, 3, 5, 8, 13\}$, missed-admission cost over $\{0, 0.1, 0.25, 0.5, 1\}$, review-load cost over $\{0, 0.02, 0.05, 0.1, 0.2\}$, and the false-admission constraint over $\{0.05, 0.10, 0.15, 0.20, 0.30\}$. Across 875 cost models per dataset, coverage-only is selected in 875/875 cases for CVEfixes and 875/875 cases for BigVul; risk-score and category-plus-coverage are selected in 0/875 cases. This does not make coverage-only a universal semantic gate. It means that, for these two proxy-label datasets and these cost ranges, the correct QG-DCA output is to select the simpler lower-debt operating point and record that the fixed strict gate should not be defended as optimal.

We then add an external component ablation using the newly downloaded Hugging Face datasets. MegaVul provides fixed true function-level vulnerability/fix pairs and same-CWE different-CVE hard controls; CIRCL vulnerability-scores adds severity and patch metadata; security-kg adds CVE/CWE/EPSS/KEV evidence chains. Table VII shows the key result. Coverage-only is already strong, but it still admits same-CWE borrowed artifacts. QG-DCA removes these admissions by requiring source CVE/commit provenance before a candidate can update $H_q(t)$. The result should be read narrowly: security-kg improves provenance and evidence reporting, but it does not improve debt-adjusted utility beyond explicit provenance in this sample.

To address the concern that exact provenance can be close to bookkeeping, we perturb the same sample with missing and spoofed provenance. With 10% spoofed same-CWE negative provenance, trusting the claimed provenance yields a false-admission rate of 0.100. QG-DCA verified admission keeps false admission at 0 by checking that the claimed source agrees with the candidate's recorded CVE/commit evidence. This is a verification-predicate stress test, not a discovered classifier capability: the claim is that spoofed evidence is rejected

MDDC evidence atlas: qualification reduces false capital and exposes boundaries

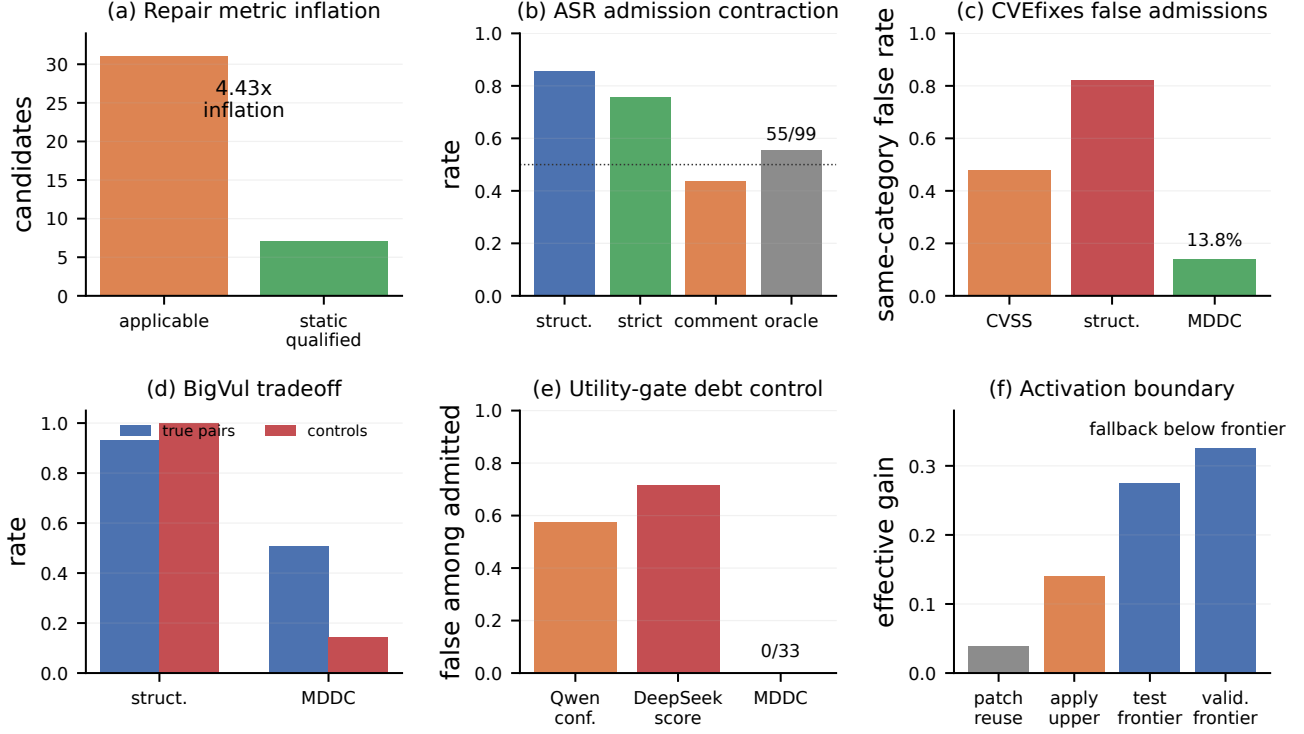


Fig. 2. MDDC evidence atlas. The panels aggregate the main evidence chain rather than reporting a single favorable endpoint: (a) repository applicability inflates qualified repair delivery, (b) ASR rule admission contracts through stricter gates, (c) CVEfixes false admissions fall under strict admission, (d) BigVul shows the recall/false-admission tradeoff, (e) utility gates avoid confidence- and score-only false capital, and (f) current CEC gain remains below the calibrated activation frontier.

by the admission rule rather than counted as capital. With 50% missing positive provenance, QG-DCA does not count coverage-supported but unverifiable artifacts as capital: recall falls to 0.499 and the abstention/validation-debt rate rises to 0.249. This is an intentional tradeoff, not a hidden success. It means that unverifiable but promising artifacts remain debt until evidence is supplied.

Table VIII turns off the main accounting components. The ablation shows that provenance verification, abstention/capital-debt separation, and recalibration remove different failure modes. The recalibration rows re-express the LXXXI operating-curve selection as an internal-component ablation; they are not a second independent dataset result. This is the strongest evidence that QG-DCA is not a single threshold: it is a ledger that records which evidence is missing, which claims fail verification, and which operating point is selected under the declared debt cost.

Finally, we test whether a stronger generator should be treated as a judge. In LXXXVI, GLM is given patch and context fields and asked to emit a candidate security predicate, but admission is still decided by the objective patch-differential gate. Table IX shows the result. GLM is useful as a candidate-oracle generator: it returns parseable, non-vacuous predicates on 40/40 tasks, with Wilson 95% CI 0.912–1.000, and covers 19/20 objective positives. However, a GLM-only

candidate gate also marks 10/20 objective negatives. This 0.50 false-candidate rate is prompt- and sample-dependent, and is reported only to illustrate why a candidate generator is not an admission gate. QG-DCA keeps the same 19/20 positive admits while admitting 0/20 negatives because the model output must pass the external patch-differential evidence gate before it updates $H_q(t)$. The 0/20 false admission is therefore a property of the verification predicate on this sample, not a discovered GLM capability. This is the intended role of LLMs in MDDC: they accelerate candidate construction, but they do not define truth.

C. RQ3: Do Raw Patches, RAG, or Stronger Models Cross the Frontier?

They do not under the measured gates. Same-CWE patch reuse yields only a weak patch-scope signal. Cross-repository RAG can contaminate context, especially for memory-safety tasks. In-repository retrieval and type-aware routing improve applicability but remain below the required knowledge-gain threshold. Stronger models produce some static-oracle successes, but model scale alone does not solve qualification.

The frozen held-out routing policy reaches 5/14, with Wilson lower bound 0.163, and does not cross either qualification frontier. The frontier calibration makes the boundary explicit: the first positive held-out test frontier is 0.275, and the more

TABLE VI
CONDENSED EVIDENCE MAP FOR KNOWLEDGE ADMISSION

Evidence group	Main result	Interpretation
Raw patch/RAG reuse	Same-CWE reuse weak; cross-repo RAG often harmful; in-repo/type routing improves applicability but stays below frontier	Raw experience is not qualified capital
Metric anti-gaming	Apply-to-static inflation is $4.43\times$; 22/80 missing-evidence cases are abstained	Proxies cannot update $H_q(t)$
Patch-to-rule capital	38 patch contexts $\rightarrow$ 16 parent/upstream-qualified predicates $\rightarrow$ 1 machine-triaged reusable-invariant candidate plus 6 abstraction candidates	Gates expose the contraction from raw context to capital
ASR pre-admission screening	112/131 structural candidate-rule admits; 108/131 strict exact-RuleID admits. Deterministic exact-comment proxy: 57/131. The full objective gate admits 99/131 under the strict hard-capital gate; balanced/lenient candidate-pool sensitivities are 107/131 and 110/131. Same-category different-rule controls admit 0 under strict, but many close non-matches under balanced	Strict objective qualification is reproducible against public ASRDataset references; looser gates are screening evidence, not hard capital; expert-label calibration remains future work
CVEfixes independent replication	Strict gate admits 6240/12668 reference-agreeing patch-context pairs and reduces same-category false admissions by 83.2% versus structural-only	Qualification-gated accounting is not limited to ASRDataset, but remains benchmark agreement rather than deployment evidence
Patch-differential oracle cross-check	55/99 strict ASR admissions validate under a patch-differential oracle surrogate; Wilson 95% CI 0.457–0.650; cross-category control false-validation rate 15.1%	Useful boundary evidence; it prevents overclaiming ASR admission as behavioral correctness and stops the planned deployment mini-trial
GLM-assisted oracle calibration	On a fixed single-seed 40-task sample, GLM emits parseable non-vacuous candidate predicates on 40/40 tasks and recalls 19/20 objective positives, Wilson 95% CI 0.764–0.991. The GLM candidate gate alone also marks 10/20 objective negatives, CI 0.299–0.701, whereas QG-DCA admits 19/20 positives and 0/20 negatives, CI 0–0.161, after the objective patch-differential gate	Supports the generator/admission separation: a strong model can create candidate oracles, but the accounting gate decides whether they become capital
External baseline comparison	CVSS-only and structural-only same-category false-admission rates are 47.9% and 82.2%; strict admission is 13.8%. Confidence-only and score-only utility baselines produce 57.5% and 71.4% false admissions among admitted candidates; the utility gate produces 0 in the measured pool	Direct comparison target for the qualification gate; supports false-capital and validation-debt reduction rather than deployment superiority
Operating-curve selection	At fixed-gate recall, strict admission beats risk-score and random admission, but tuned coverage-only has lower same-category false rates. Full operating curves and an 875-combination cost-sensitivity sweep then select coverage-only thresholds under the tested debt-cost regions	QG-DCA must be reported as an admission-accounting method with operating-point tradeoffs, not as an unconditional classifier
External component ablation	On 5954 MegaVul true pairs and 5954 same-CWE controls, coverage-only has false-admission rate 0.00067; QG-DCA without KG and full QG-DCA both reduce it to 0. security-kg adds evidence-chain context but no extra utility on top of provenance in this sample	The measured value of the new Hugging Face datasets is provenance-aware capital admission and external calibration, not deployment repair or standalone KG accuracy gain
BigVul cross-dataset replication	Strict gate admits 2247/4432 reference-agreeing pairs, Wilson 95% CI 0.492–0.522, and reduces same-category false admissions by 85.8% versus structural-only	Third public dataset replication; supports the accounting method outside Java/ASR and CVEfixes, but remains patch-context evidence
Deployment gates	Frozen 30-task run: property guidance obtains 1/30 primary security-qualified delivery and 0/30 original deployment-qualified deliveries; Vanilla obtains 0/30. One exact property-guided candidate later passes all gates under recovered native setup	Existence is shown once; deployment-rate superiority is not shown

TABLE VII
LXXXIII EXTERNAL COMPONENT ABLATION ON MEGAVUL SAME-CWE CONTROLS

Policy	Recall	False	Utility	Meaning
Risk only	0.002	0.002	-0.254	Severity is triage, not capital admission
Coverage only	0.994	0.001	0.966	Strong threshold proxy, but no provenance gate
KG consistency	0.218	0.072	-0.200	CWE/KG context alone is insufficient
Coverage+KG	0.992	0.001	0.962	Adds evidence context but not source admissibility
QG-DCA no KG	1.000	0.000	0.975	Provenance gate controls same-CWE borrowing
QG-DCA full	1.000	0.000	0.975	KG is evidence-chain enrichment in this sample

conservative validation-period frontier is 0.325. An independent recomputation from saved replay curves gives lower

interpolated zero crossings of 0.2535 for test and 0.3167 for validation, so the paper's first-positive grid values are conservative. Current patch reuse has effective gain 0.0392; even the optimistic repository-applicability upper bound is 0.1396. Both are below the activation threshold, so the measured controller should not turn them into CEC capital.

D. RQ4: What Happens Under Real Threat Pressure?

The KEV replay is used as a boundary check rather than as the main contribution. It shows that MDDC is not automatically superior under current qualification yield. AEC-only has the lowest observed debt-pressure proxy. The mean proxy is

TABLE VIII
INTERNAL QG-DCA ACCOUNTING-COMPONENT ABLATION

Component	Component off	Full QG-DCA	Failure off	Failure full	Meaning
Provenance verification	Trust claimed provenance under 10% spoofing	Verify source before admission	0.100	0.000	Verification rejects spoofed provenance rather than admitting it as capital
Abstention and capital-debt separation	Admit coverage-supported missing-provenance artifacts	Record missing provenance as validation debt	0.249	0.000	Without the debt ledger, missing evidence is silently counted as capital
Verification plus abstention	Claimed provenance OR coverage under combined dropout/spoofing	Verified provenance plus abstention	0.349	0.000	The full gate avoids both spoofed false capital and hidden missing-evidence debt, at the cost of lower recall
Recalibration on CVEfixes	Fixed strict gate	Selected operating point	0.133	0.061	Recalibration avoids defending a dominated fixed gate; utility changes from -0.063 to 0.193
Recalibration on BigVul	Fixed strict gate	Selected operating point	0.143	0.032	Recalibration avoids defending a dominated fixed gate; utility changes from -0.057 to 0.365

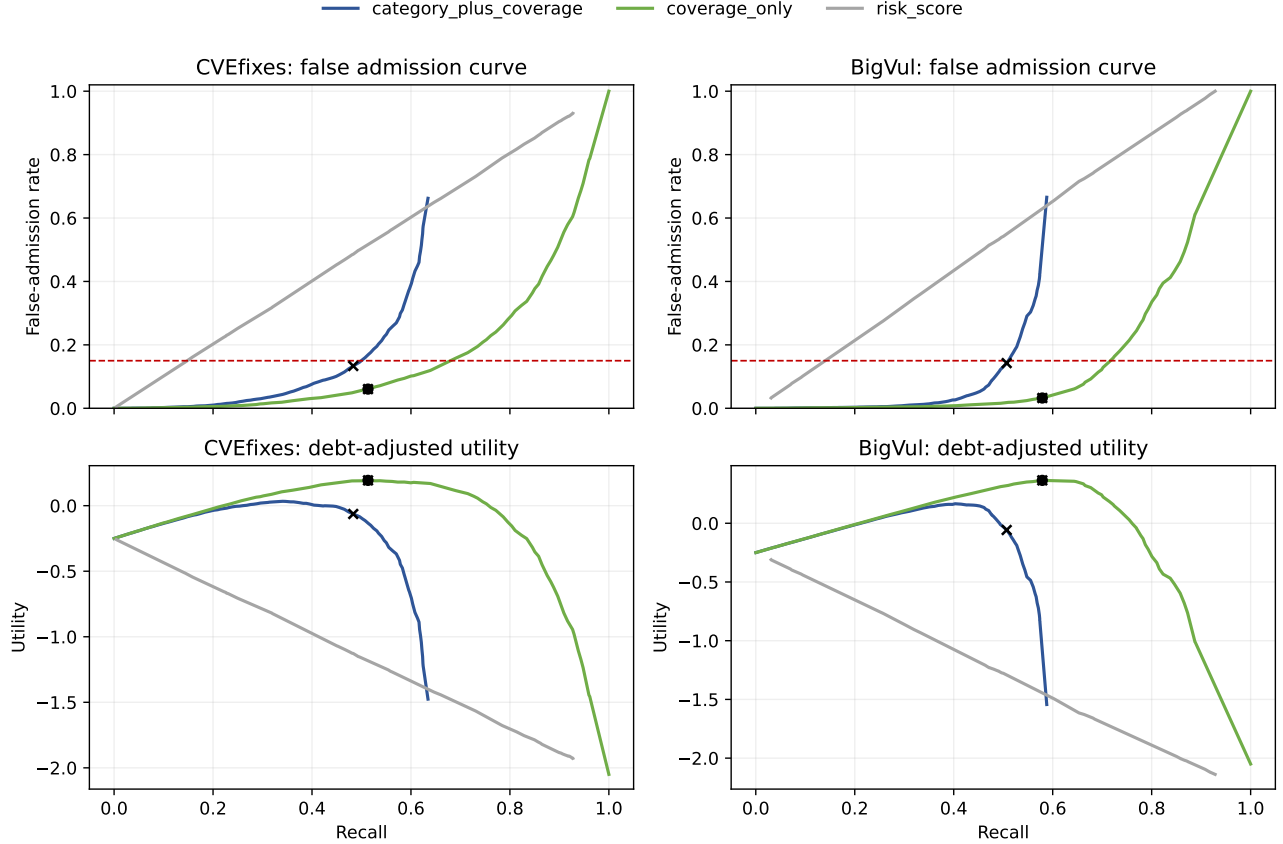


Fig. 3. Operating-curve selection for QG-DCA. The fixed strict gate is one point on the category-plus-coverage curve, not the method itself. Under the declared validation-debt cost model, QG-DCA selects coverage-only thresholds on both CVEfixes and BigVul because they provide higher debt-adjusted utility while satisfying the false-admission constraint.

TABLE IX
LXXXVI GLM-ASSISTED ORACLE CALIBRATION

Admission rule	Positive recall	Negative false admit	Interpretation
GLM candidate predicate gate	19/20; CI 0.764–0.991	10/20; CI 0.299–0.701	Strong candidate generation, unsafe as admission truth
QG-DCA objective admission	19/20; CI 0.764–0.991	0/20; CI 0–0.161	Candidate retained only when patch-differential evidence qualifies it

0.300 for AEC-only, 0.432 for MTD-like switching, 0.477 for MDDC under the current low-yield generation pipeline, and 0.990 for Static defense. This proxy is computed from public replay and validation-debt observables; it is not a production measurement of full management entropy and should not be read as a general operational ranking. The result does not show that AEC-only is universally better. It shows that always-on MDDC is wrong when generated output cannot be admitted fast enough.

This boundary changes the role of MDDC. The policy

should not activate because many candidates were generated. It should activate only when qualified yield is high enough to offset validation debt. Otherwise the correct action is fallback, rejection, or abstention. With the property-capital coefficient measured at 0.44498, the calibration estimates that downstream quality must reach $s_{quality} \geq 0.618$ to cross the test frontier and $s_{quality} \geq 0.730$ to cross the conservative validation frontier. Perturbing the property coefficient by $\pm 20\%$ moves the validation requirement from 0.609 to 0.913, and observed patch reuse remains below the test frontier even under a +20% gain perturbation. Rolling-origin, budget, and attack-regime audits show that thresholds move with time and resources; for example, budget-scaled validation thresholds range from 0.275 to 0.375. This turns the negative KEV result into a design rule: below the calibrated frontier, MDDC should

TABLE X
EXTERNAL BASELINE COMPARISON FOR FALSE-CAPITAL ADMISSION

Benchmark	Policy	Admission volume	True/admitted signal	False-admission signal	Meaning
CVEfixes true pairs	CVSS-only	6093/12668	0.481, Wilson [0.472, 0.490]	Same-category false rate 0.479, trial interval [0.451, 0.504]	Risk score alone is not an artifact-admission gate
CVEfixes true pairs	Structural-only	10302/12668	0.813, Wilson [0.806, 0.820]	Same-category false rate 0.822, trial interval [0.801, 0.842]	High recall but high false capital
CVEfixes true pairs	MDDC strict gate	6240/12668	0.493, Wilson [0.484, 0.501]	Same-category false rate 0.138, trial interval [0.119, 0.157]	Reduces false admission by 71.2% vs CVSS-only and 83.2% vs structural-only
Utility pool	Qwen confidence-only	80/80 admitted	34 true positives; precision 0.425	46/80 false among admitted; Wilson [0.466, 0.677]	Confidence admits many validation-debt candidates
Utility pool	DeepSeek score-only	21/80 admitted	6 true positives; precision 0.286	15/21 false among admitted; Wilson [0.500, 0.862]	Higher score is still not qualification
Utility pool	MDDC utility gate	33/80 admitted	33 true positives; precision 1.000	0/33 false among admitted; Wilson [0.000, 0.104]	Gate evidence controls false capital in the measured pool

TABLE XI
OPERATING-CURVE SELECTED POINTS VERSUS FIXED STRICT REFERENCE

Dataset	Selection	Policy	Recall	False	Precision	Utility	Interpretation
CVEfixes	QG-DCA selected	Coverage-only, threshold 0.145	0.513	0.061	0.931	0.193	Lower-debt point selected by the declared cost model
CVEfixes	Fixed strict reference	Category+coverage, threshold 0.101	0.483	0.133	0.852	-0.063	Conservative but dominated under this cost model
BigVul	QG-DCA selected	Coverage-only, threshold 0.179	0.579	0.032	0.908	0.365	Lower-debt point selected by the declared cost model
BigVul	Fixed strict reference	Category+coverage, threshold 0.098	0.507	0.142	0.663	-0.057	Conservative but dominated under this cost model

protect the system from CEC over-activation.

E. RQ5: Does the Gate Policy Deliver Deployable Repairs?

Only at existence level, not as a robust rate claim. The frozen 30-task all-gate run evaluates tasks with static, native, and dynamic gates under the LX admission list. Context-qualified property guidance applies on 24/30 tasks, reaches 3/30 static-safe candidates, 1/30 dynamic-safe candidate, and 1/30 primary security-qualified delivery. The paired Vanilla arm also applies on 24/30 tasks but reaches 0/30 static-safe, 0/30 dynamic-safe, and 0/30 primary security-qualified deliveries. Neither arm reaches the original deployment endpoint in the frozen run because native recovery was not counted post hoc.

The exact property-guided candidate for ‘LLMCEC-0047’ was then re-probed under a documented recovered-native setup. The same candidate passes repository, static, dynamic, and native gates, giving one same-candidate all-gate existence case. This shows that the measurement chain is not vacuous. It does not prove a deployment-rate advantage, because the native recovery was post-hoc and task-specific.

The targeted follow-up on ‘LLMCEC-0068’ gives the opposite boundary: a post-hoc feedback candidate passes repository, static, and dynamic security gates, but pnpm-aware native testing still times out for both parent and candidate. It remains validation-debt evidence, not a second all-gate positive.

An exploratory gate-feedback second attempt over the remaining 29 first-run failures produces 0/29 primary security-qualified and 0/29 deployment-qualified deliveries. This reinforces the core boundary: feedback and richer context do not automatically translate into qualified delivery. MDDC’s contribution is that it makes the existence case, the original-rate failure, and the second-attempt failure separately measurable.

VI. DISCUSSION

The empirical sequence supports a narrower and more defensible paper than the original full version. MDDC is

not a proof that LLMs automatically repair vulnerabilities. It is a measurement method that determines when AI security artifacts can be admitted as defense capital and when they must remain validation debt.

A. What MDDC Provides

MDDC provides four concrete mechanisms. First, it defines a shared state so threat pressure, remediation debt, validation debt, knowledge capital, and resource allocation can be measured together. Second, it defines a qualification invariant: unqualified generated output cannot update $H_q(t)$. Third, it introduces ABSTAIN as an explicit policy action for missing evidence. Fourth, it turns gate order into a measurable resource-allocation decision.

B. What the Evidence Supports

The evidence supports five claims. First, naive admission is unsafe: apply-only metrics and replay-only metrics inflate qualified security delivery. Second, context can produce useful candidate defense objects when it is transformed into checkable forms, but each step loses candidates through qualification. The full ASR audit shows that rule-capital admission can be measured through reproducible predicates rather than subjective author judgment. Third, the external baseline comparison shows that CVSS-only, structural-only, confidence-only, and score-only policies admit substantially more false capital than gated admission. Fourth, the gate-accounting pattern transfers beyond ASRDataset to CVEfixes and BigVul, where strict admission sharply reduces same-category false admissions. Fifth, the matched-recall, operating-curve, and cost-sensitivity analyses show that this is not an unconditional classifier result. Tuned coverage-only baselines can dominate the fixed strict gate on close-control false admission, and QG-DCA should select those lower-debt operating points under the tested cost regions. The provenance stress test

TABLE XII
MAIN POSITIVE AND NEGATIVE CLAIMS AFTER QUALIFICATION

Claim	Status
Context can produce candidate defense capital	Supported as gated pre-admission evidence plus sampled objective semantic qualification
Structural ASR rule screening scales	Supported by full ASR audit
ASR objective semantic qualification	57/131 exact-comment proxy; 99/131 strict hard-capital admissions; balanced/lenient screening sensitivities 107/131 and 110/131; same-category different-rule controls 0 only for strict
CVEfixes independent gate replication	Supported: strict gate admits 6240/12668 reference-agreeing pairs and reduces same-category false admissions by 83.2% versus structural-only
External baselines	Supported for false-admission reduction: strict MDDC reduces CVEfixes same-category false admissions by 71.2% versus CVSS-only and 83.2% versus structural-only; utility-gate false admissions are 0 in the measured pool versus 57.5% and 71.4% for confidence/score baselines
Operating-point superiority	Supported only as accounting selection: fixed strict is dominated by coverage-only under the declared cost model and across the tested cost-sensitivity grid, so QG-DCA selects the lower-debt coverage operating point
BigVul third-dataset replication	Supported: strict gate admits 2247/4432 true pairs and reduces same-category false admissions by 85.8% versus structural-only
Patch-differential oracle validation	Boundary: 55/99 strict ASR admissions validate, but cross-category false validation is 15.1%; not sufficient for deployment mini-trial activation
CEC activation boundary	Supported as a reproducible calibration rule: current gains fall below the 0.275/0.325 first-positive frontiers, so AEC-only fallback is selected; sensitivity checks show the values are dataset-calibrated and budget/window-dependent
Pre-specified routing crosses frontier	Not supported
Deployment-level repair superiority	Not supported; frozen 30-task run is 1/30 primary and 0/30 original deployment; one recovered-native existence case only

adds a narrower systems claim: unverifiable or spoofed source evidence should be recorded as rejected output or validation debt, not silently admitted as knowledge capital. The GLM oracle-calibration result adds the model-facing version of the same claim: a strong LLM can generate useful candidate predicates, but the LLM-only candidate gate would admit many objective negatives unless an external qualification gate controls admission. Thus, QG-DCA's value is the accounting and operating-point discipline, not a claim that one fixed gate or one model is always optimal.

C. What Remains Unproven

Four limitations remain. First, the deterministic ASR qualification gate is measured against public ASRDataset ground-

truth rules, not a human gold standard; CVEfixes and BigVul are patch-context benchmark-agreement replications rather than human semantic judgments. This is intentional for reproducibility, but it means that future work should calibrate the gates against independent expert labels or stronger executable oracles to estimate semantic error rates. Second, the patch-differential oracle surrogate is not strong enough for a deployment mini-trial because it has a non-negligible false-validation rate. Third, the fixed strict gate is not Pareto-optimal once recall and debt costs are reported. A tuned coverage-only filter can have lower close-control false admission, so QG-DCA should be read as a policy-evaluation method that forces operating-point reporting and selection. Fourth, the recovered-native all-gate result is one post-hoc existence case, not a pre-registered deployment-rate result; the 'LLMCEC-0068' diagnosis remains a native-test-debt boundary case rather than a second positive. The provenance stress test also shows a real cost: under 50% positive-provenance dropout, QG-DCA records an abstention/validation-debt rate of 0.249 and loses recall rather than admitting missing-evidence artifacts. The GLM calibration is also a small fixed-sample oracle-construction test, not a general proof that GLM-generated predicates are semantically correct. The debt-pressure proxy is a replay metric over public data and validation-debt logs, not a production measurement of full management entropy.

D. Threats to Validity

Construct validity is the main threat. ASR, CVEfixes, BigVul, and MegaVul gates measure benchmark agreement, provenance consistency, and conservative admission, not human semantic truth. The patch-differential oracle check strengthens this warning by showing that a surrogate oracle can still admit false validations. The provenance stress test is also a proxy-label accounting test: rejecting spoofed provenance is a verification property, and the observed 0.249 abstention/debt rate under missing provenance should be interpreted as a cost of conservative accounting rather than proof of security correctness. The operating-curve and cost-sensitivity analyses add a second warning: lower false admission can be obtained by a tuned coverage-only filter across the tested cost grid, so the fixed strict gate is not a universally optimal classifier. This is why the paper avoids claiming absolute rule correctness, deployment readiness, or gate optimality. Internal validity depends on replay assumptions: CISA due dates are remediation windows rather than actual fix times, and the activation frontier depends on the selected gain grid, budget, seed set, and validation window. The threshold audit records input hashes, recomputes the 0.275/0.325 first-positive frontiers, and reports interpolated and sensitivity ranges, but it does not make those values portable constants. External validity is limited by public vulnerability data and open-source repair tasks. Enterprise workflows, proprietary code, and different validation gates would require recalibration. Conclusion validity is limited by deployment evidence: the all-gate result is one recovered-native existence case, not a deployment-rate estimate.

E. Implication for AI Security Systems

The main implication is that AI defense needs admission control before acceleration can safely become capability. Stronger generation increases the number of candidate actions. MDDC asks whether those actions reduce risk after validation cost, not whether they look plausible. This distinction is especially important for systems that use LLMs to generate patches, rules, or assertions from rich context.

VII. CONCLUSION

This paper reframes MDDC as a qualification-gated measurement method for context-qualified AI defense actions. Its contribution is the distinction between generated artifacts and admitted defense capital. The experiments show that ordinary patch reuse, cross-repository RAG, and simple generation do not cross the frontier, and that repository applicability can seriously overstate qualified security delivery. They also show a constructive path: context can become candidate property, rule, or oracle capital after explicit gates, and becomes qualified capital only when the required semantic or behavioral evidence is present.

The current evidence supports static-oracle feasibility, scalable rule-capital pre-admission, objective benchmark-based qualification on ASRDataset, false-admission reduction on CVEfixes and BigVul, a yield-threshold activation boundary, and one recovered-native all-gate existence case. It does not support deployment-level superiority. It also shows that the fixed strict gate is not Pareto-optimal: operating-curve and cost-sensitivity analyses select tuned coverage-only thresholds with lower validation-debt cost. This boundary is not a weakness to hide. It is the main systems lesson. AI defense should not count generated artifacts as capability until they pass the gates required for their intended use, and it should not activate CEC paths when qualified yield remains below the frontier. QG-DCA makes these tradeoffs visible by requiring each admission policy to report recall, false admission, validation debt, cost sensitivity, and deployment boundary separately.

Artifact availability. The project repository contains replay scripts, prompt templates, oracle registries, result tables, figures, and the full archival manuscript. The threshold audit records hashes for the replay curves used to reproduce the 0.275/0.325 frontiers. A DOI-ready QG-DCA reproducibility package has been prepared with scripts, result tables, figures, experiment reports, pre-registration notes, data metadata, an MIT license, a checksum manifest, and Zenodo metadata. The package manifest records checksums for packaged files; the final archive hash should be reported in the public release record. Before submission, this package should be uploaded to a public archive and the assigned DOI should replace this checksum-only reference. The shortened version preserves only the evidence needed for the measurement-paper claim; detailed proofs and chronological experiment logs remain in the full supplement.

REFERENCES

- [1] J. P. Farwell and R. Rohozinski, "Stuxnet and the future of cyber war," *Survival*, vol. 53, no. 1, pp. 23–40, 2011.
- [2] N. Perloth, *This Is How They Tell Me the World Ends: The Cyber-weapons Arms Race*. London, UK: Bloomsbury Publishing, 2021.
- [3] R. Ross, M. McEvilly, and J. C. Oren, "Engineering Trustworthy Secure Systems," NIST, Gaithersburg, MD, USA, Special Publication 800-160, vol. 1, rev. 1, Nov. 2022.
- [4] R. Anderson, "Why information security is hard—an economic perspective," in *Proceedings of the 17th Annual Computer Security Applications Conference (ACSAC)*, New Orleans, LA, USA, pp. 358–365, 2001.
- [5] J. Wu, *Cyberspace Mimic Defense: Generalized Robust Control and Endogenous Security*. Singapore: Springer Nature, 2020.
- [6] P. M. Romer, "Endogenous technological change," *Journal of Political Economy*, vol. 98, no. 5, pp. S71–S102, 1990.
- [7] J. H. Cho, D. P. Sharma, H. Almgren, and S. Xu, "Toward proactive, adaptive defense: A survey on moving target defense," *IEEE Communications Surveys & Tutorials*, vol. 22, no. 1, pp. 709–745, 2020.
- [8] M. Jafarian, E. Al-Shaer, and Q. Duan, "Openflow random host mutation: Transparent moving target defense using SDN," in *Proceedings of the 1st Workshop on Hot Topics in Software Defined Networking (HotSDN)*, Helsinki, Finland, pp. 127–132, 2012.
- [9] C. Puliafito, C. Vallati, E. Mingozzi, G. Merlino, F. Longo, and A. Puliafito, "Container migration in the fog: A performance evaluation," *Sensors*, vol. 19, no. 7, p. 1488, 2019.
- [10] Q. Zhu and T. Başar, "Game-theoretic methods for robustness, security, and resilience of cyber-physical control systems: Games-in-games principle," *IEEE Control Systems Magazine*, vol. 35, no. 1, pp. 46–65, 2015.
- [11] P. K. Manadhata and J. M. Wing, "An attack surface metric," *IEEE Transactions on Software Engineering*, vol. 37, no. 3, pp. 371–386, 2011.
- [12] J. Wu, "Cyberspace endogenous safety and security development paradigm (in Chinese)," *Scientia Sinica Informationis*, vol. 52, no. 2, pp. 189–204, 2022.
- [13] J. Wu, "Cyberspace endogenous safety and security," *Engineering*, vol. 12, pp. 1–3, Jan. 2022.
- [14] Z. Li, G. Cheng, J. Tan, C. Wu, and J. Wu, "ESMD-Flow: An intelligent flow forwarding scheme with endogenous security based on Mimic defense in space-air-ground integrated network," *China Communications*, vol. 19, no. 1, pp. 40–51, Jan. 2022.
- [15] W. Wang, G. Cheng, S. Chen, H. Zhang, and X. Jing, "Security analysis of dynamic heterogeneous redundant system (in Chinese)," *Computer Engineering*, vol. 44, no. 10, pp. 42–50, 2018.
- [16] L. Leite, C. Rocha, F. Kon, D. Milojevic, and P. Meirelles, "A survey of DevOps concepts and challenges," *ACM Computing Surveys*, vol. 52, no. 6, pp. 1–35, 2019.
- [17] M. Shahin, M. A. Babar, and L. Zhu, "Continuous integration, delivery and deployment: A systematic review on approaches, tools, challenges and practices," *IEEE Access*, vol. 5, pp. 3909–3943, 2017.
- [18] S. Crane, S. Volckaert, F. Schuster, C. Liebchen, P. Larsen, L. Davi, A. R. Sadeghi, T. Holz, and M. Franz, "It's a TRaP: Table randomized address space protection for mitigating control-flow attacks," in *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS)*, Denver, CO, USA, pp. 466–477, 2015.
- [19] H. Hu, Z. L. Chua, S. Adrian, P. Saxena, and Z. Liang, "Automated generation of data-oriented exploits," in *Proceedings of the 24th USENIX Security Symposium*, Washington, D.C., USA, pp. 201–216, 2015.
- [20] L. A. Gordon and M. P. Loeb, "The economics of information security investment," *ACM Transactions on Information and System Security*, vol. 5, no. 4, pp. 438–457, 2002.
- [21] R. Böhme and T. Moore, "The iterated weakest link," *IEEE Security & Privacy*, vol. 14, no. 1, pp. 81–85, 2016.
- [22] A. Laszka, M. Felegyhazi, and L. Buttyan, "A survey of interdependent information security games," *ACM Computing Surveys*, vol. 47, no. 2, Art. no. 23, 2014.
- [23] R. M. Solow, "A contribution to the theory of economic growth," *The Quarterly Journal of Economics*, vol. 70, no. 1, pp. 65–94, 1956.
- [24] W. J. Baumol, "Macroeconomics of unbalanced growth: The anatomy of urban crisis," *The American Economic Review*, vol. 57, no. 3, pp. 415–426, 1967.
- [25] Q. Zhu and T. Başar, "Robust and resilient control design for cyber-physical systems with an application to power systems," in *Proceedings of the 50th IEEE Conference on Decision and Control (CDC)*, Orlando, FL, USA, pp. 4066–4071, 2011.
- [26] E. M. Hutchins, M. J. Cloppert, and R. M. Amin, "Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains," *Leading Issues in Information Warfare & Security Research*, vol. 1, pp. 80–106, 2011.
- [27] J. R. Boyd, "The essence of winning and losing," 1996. Online available: <https://www.coljohnboyd.com>. Accessed on: Feb. 5, 2026.

- [28] B. Strom, A. Applebaum, D. Miller, K. Nickels, C. Pennington, and C. Thomas, "MITRE ATT&CK: Design and philosophy," The MITRE Corp., Bedford, MA, USA, Tech. Rep., Mar. 2020.
- [29] D. E. Kirk, *Optimal Control Theory: An Introduction*. Mineola, NY, USA: Dover Publications, 2004.
- [30] H. K. Khalil, *Nonlinear Systems*, 3rd ed. Upper Saddle River, NJ, USA: Prentice Hall, 2002.
- [31] K. Ogata, *Modern Control Engineering*, 5th ed. Upper Saddle River, NJ, USA: Pearson, 2010.
- [32] J. D. Sterman, *Business Dynamics: Systems Thinking and Modeling for a Complex World*. New York, NY, USA: McGraw-Hill, 2000.
- [33] M. Kermack and A. McKendrick, "A contribution to the mathematical theory of epidemics," *Proceedings of the Royal Society of London. Series A*, vol. 115, no. 772, pp. 700–721, 1927.
- [34] Verizon, "2024 Data Breach Investigations Report (DBIR)," Verizon Enterprise Solutions, Tech. Rep., 2024.
- [35] L. Ablon and A. Bogart, "Zero Days, Thousands of Nights: The Life and Times of Zero-Day Vulnerabilities and Their Exploits," RAND Corp., Santa Monica, CA, USA, Res. Rep. RR-1751, 2017.
- [36] Google Cloud, "Accelerate State of DevOps Report 2023," DORA, Tech. Rep., 2023.
- [37] Mandiant, "M-Trends 2024: Special Report," Mandiant, Tech. Rep., 2024.
- [38] A. Wool, "A quantitative study of firewall configuration errors," *Computer*, vol. 37, no. 6, pp. 62–67, 2004.
- [39] E. Al-Shaer and H. Hamed, "Discovery of policy anomalies in distributed firewalls," in *Proceedings of IEEE INFOCOM*, vol. 4, pp. 2605–2616, 2004.
- [40] H. Pearce, B. Ahmad, B. Tan, B. Dolan-Gavitt, and R. Karri, "Asleep at the keyboard? Assessing the security of GitHub Copilot's code contributions," in *Proceedings of the 43rd IEEE Symposium on Security and Privacy (S&P)*, San Francisco, CA, USA, pp. 755–768, 2022.
- [41] G. A. N. Al-Sultany, R. Al-Zaidy, and X. Yuan, "Deep learning for cyber security applications: A comprehensive survey," *IEEE Access*, vol. 10, pp. 104518–104539, 2022.
- [42] A. Egtesad, Y. Vorobeychik, and A. Laszka, "Adversarial deep reinforcement learning based adaptive moving target defense," in *Proc. Decision and Game Theory for Security (GameSec)*, pp. 58–79, 2020.
- [43] X. Han, N. Kheir, and D. Balzarotti, "Deception techniques in computer security: A research perspective," *ACM Comput. Surv.*, vol. 51, no. 4, pp. 1–36, 2018.
- [44] S. Souppaya, M. Morello, and K. Scarfone, "Application container security guide," NIST Special Publication 800-190, 2017.
- [45] M. Chandramouli, "Building Secure Microservices-based Applications Using Service-Mesh Architecture," NIST Special Publication 800-204A, National Institute of Standards and Technology, 2022.
- [46] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," NIST Special Publication 800-207, 2020.
- [47] M. Souppaya, J. Morello, and K. Scarfone, "Securing the Software Supply Chain: Recommended Practices Guide for Developers," NIST Special Publication 800-218, National Institute of Standards and Technology, 2022.
- [48] IBM Security, "Cost of a Data Breach Report 2023," IBM Corp., Tech. Rep., 2023.
- [49] Kubernetes Authors, "Pod Lifecycle: Container Restart Policy," 2024. Online available: <https://kubernetes.io>. Accessed on: Feb. 5, 2026.
- [50] CRIU Developers, "CRIU: Checkpoint/Restore In Userspace - Performance Benchmarks," 2023. Online available: <https://criu.org>. Accessed on: Feb. 5, 2026.
- [51] T. Menzies, J. Greenwald, and A. Frank, "Data mining static code attributes to learn defect predictors," *IEEE Transactions on Software Engineering*, vol. 33, no. 1, pp. 2–13, 2007, doi: 10.1109/TSE.2007.10.
- [52] T. Zimmermann, N. Nagappan, H. Gall, E. Giger, and B. Murphy, "Cross-project defect prediction: A large scale experiment on data vs. domain," in *Proc. Joint Meeting of the European Software Engineering Conf. and ACM SIGSOFT Symp. Foundations of Software Engineering (ESEC/FSE)*, pp. 91–100, 2009, doi: 10.1145/1595696.1595713.
- [53] N. Bettenburg, S. Just, A. Schröter, C. Weiss, R. Premraj, and T. Zimmermann, "What makes a good bug report?" in *Proc. ACM SIGSOFT Int. Symp. Foundations of Software Engineering (FSE)*, pp. 308–318, 2008, doi: 10.1145/1453101.1453146.
- [54] K. Herzig, S. Just, and A. Zeller, "It's not a bug, it's a feature: How misclassification impacts bug prediction," in *Proc. IEEE/ACM Int. Conf. Software Engineering (ICSE)*, pp. 392–401, 2013, doi: 10.1109/ICSE.2013.6606587.
- [55] Y. Shin, A. Meneely, L. Williams, and J. A. Osborne, "Evaluating complexity, code churn, and developer activity metrics as indicators of software vulnerabilities," *IEEE Transactions on Software Engineering*, vol. 37, no. 6, pp. 772–787, 2011, doi: 10.1109/TSE.2010.81.
- [56] P. Morrison, K. Herzig, B. Murphy, and L. Williams, "Challenges with applying vulnerability prediction models," in *Proc. Symp. and Bootcamp on the Science of Security (HotSoS)*, Art. no. 4, 2015, doi: 10.1145/2746194.2746198.
- [57] National Institute of Standards and Technology, "National Vulnerability Database: CVE JSON 2.0 Feeds," 2026. [Online]. Available: <https://nvd.nist.gov/vuln/data-feeds>
- [58] Cybersecurity and Infrastructure Security Agency, "Known Exploited Vulnerabilities Catalog," 2026. [Online]. Available: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [59] FIRST, "Exploit Prediction Scoring System (EPSS)," 2026. [Online]. Available: <https://www.first.org/epss/>
- [60] G. Bhandari, A. Naseer, and L. Moonen, "CVEfixes: Automated Collection of Vulnerabilities and Their Fixes from Open-Source Software," in *Proc. 17th Int. Conf. Predictive Models and Data Analytics in Software Engineering*, 2021; dataset v1.0.8, Zenodo, 2024, doi: 10.5281/zenodo.13118970.
- [61] J. Fan, Y. Li, S. Wang, and T. N. Nguyen, "A C/C++ Code Vulnerability Dataset with Code Changes and CVE Summaries," in *Proc. IEEE/ACM 17th Int. Conf. Mining Software Repositories (MSR)*, pp. 508–512, 2020, doi: 10.1145/3379597.3387501.
- [62] H. Asghari, M. van Eeten, A. Bauer, and C. Ganan, "The Unpatchables: Why Municipalities Persist in Running Vulnerable Hosts," in *Proc. USENIX Security Symposium*, 2024.
- [63] Z. Yu, W. Zhang, and Y. Wang, "PATCHAGENT: A Practical Program Repair Agent Mimicking Human Patch Strategy," in *Proc. USENIX Security Symposium*, 2025.
- [64] W. Liu, H. Hu, L. Chen, M. Zhang, and T. Liu, "PropertyGPT: LLM-driven Formal Verification of Smart Contracts through Retrieval-Augmented Property Generation," in *Proc. Network and Distributed System Security Symposium (NDSS)*, 2025.